

DOCUMENTO DE AUDITORÍA: INFORME DE ANÁLISIS DE EXPOSICIÓN AUTOMATIZADA Y CONTROL REMOTO (REVERSE SHELL)

Fecha de Ejecución: 8 de Julio de 2026

Analista Responsable: Federico Fijtman (Técnico Superior en Programación / Analista GRC)

Herramienta Utilizada: Metasploit Framework MSFv6 (Motor Avanzado de Penetración)

Objetivo Auditado (Target): Servidor Linux Vulnerable - IP 192.168.56.101 (Metasploitable 2)

1. OBJETIVO DE LA AUDITORÍA TÉCNICA

El propósito de esta evaluación es validar la seguridad del sistema frente al uso del framework Metasploit para la detección, configuración y ejecución de vectores de ataque de manera automatizada. Se simulará el comportamiento de una amenaza avanzada para analizar cómo un componente de software permite evadir las políticas de seguridad de la red interna mediante una carga útil (*payload*) de conexión reversa (*reverse shell*).

2. PROCEDIMIENTO TÉCNICO Y RESOLUCIÓN DE CONFLICTOS (PASO A PASO)

- **Paso 2.1: Indexación en la Fase de Datos:** Se inició el motor PostgreSQL de Kali Linux y se ejecutó una búsqueda de indexación bajo el parámetro de vulnerabilidad global CVE-2021-2525, logrando cargar el módulo correspondiente para el servidor objetivo.
- **Paso 2.2: Configuración de Variables Perimetrales:** Se parametrizó la variable remota RHOSTS apuntando al objetivo 192.168.56.101. Para la recepción de la conexión, se configuró un *payload* de tipo *reverse shell* (intérprete Meterpreter) apuntando a la interfaz IP de la máquina atacante (192.168.56.1).
- **Paso 2.3: Gestión de Infraestructura y Sockets de Red:** Durante el primer intento de intrusión, el framework reportó un conflicto por asignación de memoria, debido a que el puerto oculto 2200 se encontraba saturado por procesos persistentes previos. Se procedió a la finalización de dichos procesos mediante la ejecución de un script de limpieza de sockets para purgar la caché de la NIC y liberar los sockets de red.
- **Paso 2.4: Explotación y Ganancia de Acceso:** Una vez limpia la conexión, se ejecutó el comando de ataque exploit. El *exploit* evadió los mecanismos de seguridad del servidor objetivo, abriendo un canal de comunicación bidireccional cifrado en la memoria RAM del servidor.

```
kali@kali: ~/Desktop
Session Actions Edit View Help

Stdapi: System Commands

Command      Description
-----
execute      Execute a command
getenv       Get one or more environment variable values
getpid       Get the current process identifier
getuid       Get the user that the server is running as
kill         Terminate a process
localtime    Displays the target system local date and time
pgrep        Filter processes by name
pkill        Terminate processes by name
ps           List running processes
shell        Drop into a system command shell
suspend      Suspends or resumes a list of processes
sysinfo      Gets information about the remote system, such as OS

Stdapi: Webcam Commands

Command      Description
-----
webcam_chat  Start a video chat
webcam_list  List webcams
webcam_snap  Take a snapshot from the specified webcam
webcam_stream Play a video stream from the specified webcam

Stdapi: Mic Commands

Command      Description
-----
listen       listen to a saved audio recording via audio player
mic_list     list all microphone interfaces
mic_start    start capturing an audio stream from the target mic
mic_stop     stop capturing audio

Stdapi: Audio Output Commands

Command      Description
-----
play         play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > |
```

3. CONCLUSIÓN Y ANÁLISIS DE IMPACTO PARA EL CISO

La obtención de la sesión interactiva de **Meterpreter** representa el nivel máximo de compromiso del sistema ante un vector de ataque. Este tipo de *payload* permite al atacante operar directamente cargado en la memoria RAM, evadiendo los sistemas de detección tradicionales y permitiendo la ejecución de comandos nativos con privilegios de administrador (*root*).

Recomendación Obligatoria de Gobierno y Riesgo: Se solicita el aislamiento total del servidor afectado hasta que una nueva versión del servicio sea desplegada en el área de infraestructura de almacenamiento.